



KKMTM

2026 RÉFÉRENTIEL NORMATIF ET RÉGLEMENTAIRE DE CYBERSÉCURITÉ



KKMTM

DRIVING INNOVATION, ELEVATING TECHNOLOGY

Référentiel normatif et réglementaire de cybersécurité – KKMTM

1. Objet du document

Le présent document constitue le document de référence principal de la gouvernance de la cybersécurité de l'entreprise KKMTM.

Il a pour objectif de définir le cadre normatif, réglementaire et méthodologique applicable à la sécurité des systèmes d'information IT, OT et IIoT, ainsi qu'à la gestion des risques associés.

Il sert de :

- Référentiel central de cybersécurité,
- Base de conception et d'architecture sécurisée,
- Support de conformité réglementaire et normative,
- Point d'appui pour les analyses de risques, audits et évolutions futures du système d'information.

Les normes et réglementations présentées dans ce document sont utilisées comme cadres de référence, et non comme certifications formelles, sauf mention contraire.



2. Champ d'application (périmètre)

Le périmètre couvert par le présent document inclut notamment :

- Les systèmes IT (infrastructures, réseaux, services et applications),
- Les systèmes OT / ICS (systèmes d'automatisation industrielle et de contrôle-commande),
- Les environnements IIoT,
- Les interconnexions IT/OT (DMZ industrielle, flux réseau, accès distants),
- Les aspects organisationnels, techniques et méthodologiques liés à la cybersécurité.

Ce périmètre pourra être ajusté en fonction de l'évolution des activités, des infrastructures ou du cadre réglementaire applicable à KKMTM.

3. Engagement de la direction

La direction de KKMTM reconnaît les normes et réglementations présentées dans ce document comme cadres de référence pour la cybersécurité de l'entreprise.

Le RSSI est chargé de suivre ces normes, de veiller à leur application et de s'assurer que l'entreprise reste alignée sur les exigences réglementaires et normatives.



4. Gouvernance de la cybersécurité – rôles et responsabilités

Nom	Rôle	Responsabilités
MESQUITA SANTOS Kévin DOS	Responsable du document	Garant du contenu, de sa cohérence et de son alignement avec les exigences normatives et réglementaires
MESQUITA SANTOS Kévin DOS	Rédacteur / Éditeur	Rédaction et mise à jour du document
MESQUITA SANTOS Kévin DOS	Valideur	Validation formelle des évolutions du présent document
Everyone	Lecteurs	Consultation du document dans le cadre de leurs activités

Les rôles nominativement attribués sont définis et maintenus par la gouvernance de KKMTM.



5. Gouvernance documentaire

Le présent document s'inscrit dans un référentiel documentaire centralisé garantissant :

- Une source unique de vérité,
- La cohérence des exigences de cybersécurité,
- La traçabilité des évolutions documentaires.

Le présent document s'inscrit dans la hiérarchie documentaire de KKMTM comme document de référence normatif et réglementaire, en support des politiques et procédures de cybersécurité.

5.1 Hiérarchie documentaire

Les documents de cybersécurité de KKMTM s'appuient sur les référentiels normatifs et réglementaires présentés dans ce document.

Les principaux documents concernés incluent :

- Politiques de sécurité spécifiques
- Analyses de risques IT et OT
- Standards et référentiels techniques
- Procédures opérationnelles
- Plans de continuité et de reprise d'activité

Le présent document ne contient pas de procédures opérationnelles détaillées, lesquelles sont définies dans les documents dédiés correspondants.



6. Gestion des versions

Le document est soumis à une gestion de versions permettant d'assurer la traçabilité des modifications.

Chaque version comprend :

- Un numéro de version,
- Une date de mise à jour,
- Une description synthétique des changements,
- L'identification du rédacteur et du validateur.

Une revue du document est réalisée au minimum une fois par an, ou à la suite d'un changement majeur impactant la cybersécurité de KKMTM.

7. Cadre normatif et réglementaire

Les normes et réglementations référencées dans le présent document sont utilisées pour :

- Structurer le SMSI,
- Formaliser la gestion des risques,
- Définir les mesures techniques et organisationnelles,
- Assurer l'alignement avec les exigences réglementaires européennes, notamment pour les environnements OT / ICS.



Les sections suivantes présentent les normes et réglementations de référence retenues.

Historique de Version : V1.2 – Normes et Réglementations

Date : 07/02/2026 – 11:43

Statut : En vigueur

Description synthétique des derniers changements : Ajout des normes liées et complémentaires au secteur d'activité

8. Normes ISO/IEC 27000 – SMSI et gestion des risques

- ISO/IEC 27001 : exigences pour la mise en œuvre et le maintien d'un SMSI.
- ISO/IEC 27002 : catalogue de bonnes pratiques et de contrôles de sécurité techniques et organisationnels.
- ISO/IEC 27005 : gestion des risques liés à la sécurité de l'information, applicable aux environnements IT, DMZ et OT.

9. Normes spécifiques OT / IIoT – IEC 62443

La série IEC 62443 constitue le cadre de référence principal pour la cybersécurité des systèmes d'automatisation et de contrôle industriel (IACS).

- IEC 62443-1-1 : terminologie, concepts et modèles.
- IEC 62443-2-1 / 2-4 : exigences organisationnelles, politiques et exigences applicables aux intégrateurs et fournisseurs.
- IEC 62443-3-2 : zonage, conduits et analyse de risques.
- IEC 62443-3-3 : exigences techniques détaillées applicables aux systèmes (authentification, durcissement, segmentation réseau, journalisation, etc.).

10. Réglementation européenne

- Directive NIS2 (UE) : obligations de cybersécurité applicables aux entités essentielles et importantes, avec un impact significatif sur les environnements OT / ICS.
- Cyber Resilience Act (CRA) : exigences de cybersécurité applicables aux produits numériques, équipements OT / IIoT et logiciels embarqués.
- Règlement Général sur la Protection des Données (RGPD) : cadre de protection des données personnelles lorsque les systèmes IT ou OT traitent ou exposent des données identifiantes.



11. Normes connexes – continuité et résilience

- ISO 22301 : management de la continuité d'activité, incluant les plans de reprise et les scénarios de panne ou de cyberattaque industrielle.

12. Synthèse des référentiels retenus

- ISO/IEC 27001, 27002 et 27005 pour la gouvernance du SMSI et la gestion des risques.
- IEC 62443-3-2 et 62443-3-3 pour le zonage, les conduits et les exigences techniques OT.
- NIS2 comme cadre réglementaire européen à mapper sur les mesures techniques et organisationnelles, en particulier pour les systèmes OT / ICS.

13. Normes liées et complémentaires

Les normes suivantes sont identifiées comme complémentaires et pourront être intégrées ultérieurement selon l'évolution du périmètre :

- ISO/IEC 27017 : contrôles de sécurité pour les services cloud.
- ISO/IEC 27018 : protection des données personnelles dans le cloud.
- ISO/IEC 27019 : sécurité des systèmes de contrôle utilisés dans le secteur de l'énergie.
- ISO 31000 : cadre générique de management du risque, en surcouche des approches ISO/IEC 27005 et IEC 62443.